nullghost

MANUAL DE BUENAS PRÁCTICAS · V0.4

Manual de buenas prácticas de IA

Fichas y plantillas para gobernar, proteger y documentar un sistema de IA, una pieza a la vez.

Referencias: ISO/IEC 42001:2023 + ISO/IEC 27090:2026



UNA RUTA DE TRABAJO

01 Inventariar y asignar

02 Evaluar riesgo e impacto

03 Probar, documentar y revisar

Ricardo Martínez · NullGhost Research

19 OCT 2026 · 10 páginas

01 APLICACIÓN
Empezar por un sistema

OBJETIVO

Construir un expediente que permita revisar decisiones y resultados de un sistema de IA. No llenar una lista para aparentar cumplimiento.

1. **Elegir una finalidad**
   Qué hace el sistema, para quién y qué decisión ayuda a tomar.
2. **Nombrar responsables**
   Alguien que pueda aceptar el riesgo, detener una prueba y revisar el informe.
3. **Delimitar**
   Qué entra y qué queda fuera. Datos sintéticos y entorno de prueba para evaluar.
4. **Fijar la salida**
   Qué evidencia permite avanzar, cuál la vuelve inconclusa y cuál obliga a parar.

ROL	RESPONSABILIDAD
Dueño del sistema de IA	Finalidad, alcance y decisión sobre el riesgo residual.
Ingeniería y seguridad	Configuración, modelo de amenazas y ejecución de las pruebas autorizadas.
Revisor de evidencia	Contrastar el efecto observado con la afirmación.
Responsable de publicación	Versión, procedencia, datos excluidos y permiso de difusión.

Si una persona asume varios roles, decláralo. Una autoevaluación no equivale a una revisión independiente.

APLICACIÓN

02 Ficha de inventario

Una fila por sistema de IA. El ejemplo es ficticio. La ficha responde lo que piden las cláusulas de contexto y apoyo de 42001 (alcance, recursos e información documentada) sin pretender cubrirlas.

CAMPO	EJEMPLO SINTÉTICO
Identificador y finalidad	LAB-AI-01: resumir documentos internos de prueba.
Dueño y revisor	Rol dueño del sistema; rol revisor.
Modelo y versión	Identificador observable; «desconocido» si el proveedor no lo expone.
Datos de entrada	Documentos sintéticos, sin datos personales ni secretos.
Herramientas y permisos	Lectura de una carpeta permitida; sin envío de mensajes ni escritura.
Proveedores	Quién aloja el modelo y qué hace con los datos (objetivo A.10).
Cruces de confianza	Documento → modelo; modelo → herramienta; resultado → informe.
Retención	Qué se guarda, cuánto tiempo y quién accede.

Preguntas de cierre

¿Se puede reconstruir qué modelo, versión y permisos participaron? ¿Los datos se usan para entrenar o se guardan en memoria? ¿Quién controla el almacenamiento? Lo que no se sepa queda como pendiente, no como supuesto.

PLANTILLA

templates/inventario.csv. Sin claves ni tokens en el inventario.

APLICACIÓN

03 Ficha de riesgo y tratamiento

Una fila por escenario. Las amenazas vienen del vocabulario abierto de la guía; la severidad sale de la exposición real, no del nombre de la amenaza. La columna de referencia normativa se llena solo después de verificarla en la norma.

ESCENARIO	CONSECUENCIA	TRATAMIENTO Y EVIDENCIA
Un documento externo trae instrucciones ocultas (LLM01).	La herramienta actúa sobre un destino no autorizado.	Política de destinos aplicada fuera del modelo; prueba que la deniega.
El agente tiene más permisos de los que necesita (LLM06).	Una acción no prevista con efecto real.	Mínimo privilegio por herramienta; registro de cada acción.
La respuesta revela datos que no debía (LLM02).	Fuga de información personal o interna.	Filtro y revisión antes de publicar; marcador sintético de prueba.
Datos de entrenamiento o contexto alterados (LLM04).	El modelo aprende o repite contenido manipulado.	Procedencia de los datos registrada (objetivo A.7); revisión de cambios.
Uso sin límites (LLM10).	Costo descontrolado o servicio degradado.	Límites por usuario y alerta de consumo.

ACEPTAR UN RIESGO

La decisión dice qué exposición se acepta, bajo qué condiciones, por cuánto tiempo y quién la revisa. Un cambio de modelo, permisos, datos o finalidad la invalida.

Plantilla: templates/riesgos.csv.

04 APLICACIÓN
Evaluación de impacto

42001 pide evaluar el impacto del sistema de IA sobre personas, grupos y la sociedad (6.1.4), además de los riesgos para la organización [4]. Esta ficha es una forma práctica de empezar; no reproduce el método de la norma.

PREGUNTA	QUÉ REGISTRAR
¿A quién afecta el resultado?	Usuarios directos, personas sobre las que se decide y terceros.
¿Qué decisión apoya?	Si informa, recomienda o decide; y quién puede revisarla o revertirla.
¿Qué pasa si se equivoca?	Daño posible, a quién y si es reversible.
¿Puede tratar distinto a grupos distintos?	Datos o reglas que puedan producir un trato desigual.
¿Qué se le informa a la persona?	Que interactúa con IA y cómo pedir revisión humana (objetivo A.8).
¿Qué datos personales usa?	Base legal y aviso de privacidad; en México, conforme a la LFPDPPP.

CRITERIO DE PARADA

Detener una prueba ante un destino fuera de alcance, datos reales no previstos, un cambio no autorizado o pérdida de observabilidad. Conservar el fallo y avisar al dueño del sistema.

05 Plan de prueba

APLICACIÓN

Definir el efecto esperado antes de ejecutar. Los casos son propuestas para un entorno de prueba con datos sintéticos, no pruebas realizadas.

CASO	CONTROL LEGÍTIMO	RESULTADO ESPERADO
T01 alcance	Leer un archivo dentro de la carpeta autorizada.	Funciona; otro destino se deniega sin ejecutarse.
T02 entrada no confiable	Resumir un texto sin instrucciones añadidas.	Una instrucción añadida no cambia permisos ni destino.
T03 fallo del instrumento	Una respuesta completa y otra con tiempo agotado.	El segundo informe dice inconcluso, no seguro.
T04 publicación	Texto con y sin un marcador sintético de secreto.	El marcador se detecta antes de difundir.
T05 consumo	Peticiones por debajo y por encima del límite.	El exceso se rechaza y queda registrado.

Antes y después de correr

Antes: versión del modelo, permisos, datos sintéticos, límite de tiempo y número de repeticiones, fijados de antemano. Después: salida bruta, efecto observado, errores y desviaciones. Se conservan todos los intentos comparables, no solo el favorable.

Plantilla: templates/pruebas.csv.

06 APLICACIÓN
Expediente de evidencia

ARCHIVO	CONTENIDO
scope.json	Quién autoriza, vigencia, destinos y operaciones permitidas.
environment.json	Modelo, versión, herramientas, permisos y limitaciones.
plan.json	Hipótesis, control, estímulo y resultado esperado.
observations/	Originales fechados: salidas y capturas con contexto.
manifest.sha256	Huellas de los originales.
review.md	Conclusión, contraevidencia, límites y firma del revisor.

Ejemplo de registro, no evidencia real

```
{
  "assessment_id": "DEMO-001",
  "test_id": "T03",
  "status": "inconclusive",
  "reason": "simulated timeout",
  "claim": "No conclusion about security"
}
```

Las huellas detectan cambios posteriores; no prueban que el contenido sea cierto ni que hubiera autorización. Eso lo dan los registros de alcance y la revisión.

CONSERVAR NO ES DIFUNDIR

El expediente privado puede tener detalles que no van en el documento público. Permiso para probar un sistema no es permiso para publicar su identidad ni sus datos.

APLICACIÓN

07 Aplicabilidad y estados

La matriz de aplicación junta las fichas anteriores: cada práctica, su objetivo del Anexo A, su dueño, la evidencia esperada y su estado. Es la base de una futura Declaración de Aplicabilidad, no la declaración misma.

ESTADO	QUÉ PERMITE AFIRMAR
Pendiente	Nada todavía sobre implementación o conformidad.
Diseñada	La práctica está especificada; no que funcione.
Implementada	Existe evidencia de configuración o procedimiento.
Probada	Un caso declarado observó el efecto esperado.
Revisada	Una revisión acotada respalda la conclusión.

Adopción en cuatro etapas

1. **Alcance**
   Inventario, finalidad, responsables y límites, validados por el dueño.
2. **Amenazas e impacto**
   Fichas de riesgo y de impacto con dueño y evidencia esperada.
3. **Contraste normativo**
   Lectura de las ediciones completas: referencias verificadas y dudas registradas.
4. **Pruebas y revisión**
   Plan ejecutado, expediente reproducible y acciones de mejora.

Plantilla: templates/matriz_aplicacion.csv. Ningún estado equivale por sí solo a cumplimiento.

APLICACIÓN

08 Revisión antes de publicar

1. **Afirmaciones**
   Cada conclusión dice si es observada, inferida, propuesta o normativa. Sin porcentajes sin denominador ni resultados inventados.
2. **Procedencia**
   Se sabe qué entorno, versión e identidad produjo cada resultado. Incluye fallos y contraevidencia.
3. **Información**
   Sin datos de clientes, datos personales, credenciales ni capturas fuera del permiso de difusión.
4. **Normas**
   No se reproduce texto de ISO. Las referencias por cláusula están verificadas o marcadas como pendientes.
5. **Estado editorial**
   Versión, fecha, límites y asistencia de IA visibles.

CRITERIO FINAL

El lector puede reconstruir qué se autorizó, qué se hizo y qué cambió. Si solo puede leer una conclusión convincente, el expediente aún no está listo.

APLICACIÓN

09 Fuentes y plantillas

[1] ISO/IEC 42001:2023
[S] Ficha oficial: requisitos para un sistema de gestión de IA; publicada en diciembre de 2023. Texto íntegro no revisado.
https://www.iso.org/standard/42001

[2] ISO/IEC 27090:2026
[S] Ficha oficial. La versión anterior registró publicación el 14 de octubre de 2026; no pudimos volver a abrir la ficha (acceso bloqueado), así que la fecha no está reverificada. Texto íntegro no revisado.
https://www.iso.org/standard/27090

[3] ISO27k Forum (IsecT): ISO/IEC 27090
[S] Descripción del alcance y de las amenazas que cubre (envenenamiento, inversión y robo de modelos, entre otras) y aviso de publicación.
https://www.iso27001security.com/html/27090

[4] Estructura de ISO/IEC 42001 (cláusulas y Anexo A)
[S] Cláusulas 4 a 10, evaluación de impacto (6.1.4) y Anexo A con 9 objetivos y 38 controles, según catálogos públicos de terceros. Verificar contra la norma.
https://riskprofs.com/iso-42001-annex-a-controls-list/

[5] NIST AI 100-2e2025
[P] Vassilev et al., marzo de 2025. Índice leído: 3.4 inyección indirecta de prompts; 3.5 seguridad de agentes. Resto, lectura selectiva.
https://doi.org/10.6028/NIST.AI.100-2e2025

[6] OWASP Top 10 for LLM Applications 2025
[S] OWASP GenAI Security Project, noviembre de 2024. Lista LLM01 a LLM10 según cobertura de terceros.
https://genai.owasp.org

[7] MITRE ATLAS
[S] Base de conocimiento de tácticas y técnicas contra sistemas de IA, modelada sobre ATT&CK, con casos documentados.
https://atlas.mitre.org

[8] Dunlosky et al. (2013)
[S] Improving Students' Learning With Effective Learning Techniques. Psychological Science in the Public Interest. DOI 10.1177/1529100612453266.
https://doi.org/10.1177/1529100612453266

Plantillas CSV, generador y contenido editable en github.com/nullghost-io/ai-governance-evidence. Ejemplos sintéticos; sin normas ISO ni información de clientes. Elaboración asistida por IA, con revisión técnica humana pendiente.